MERROWFIELD DIGITAL

Playbook: Insider misuse

Document Playbook 06 | Rev 3 | Effective 9 February 2026 | Owner: Security Operations | Review cycle: 12 months

1. What this playbook covers

This playbook covers deliberate misuse of legitimate access by an employee or contractor - exporting data with no business need, looking up people they know, or taking data when leaving. It is used by the Security Analyst who investigates, from the first alert until the incident is closed.

2. How it is usually recognised

- a data loss prevention alert on a bulk export
- an access review that finds searches with no ticket behind them
- queries outside the person's normal hours or role
- leaver checks that find access still in use after an end date

3. The first hour

1. Suspend the account.
2. Preserve evidence under legal hold before anyone speaks to the person.
3. Engage HR and legal.
4. Ask any external recipient - a personal email address or cloud drive - to delete the data and confirm in writing.
5. Review what else the account could reach.

4. Evidence to preserve

- query and export logs
- data loss prevention events
- email, removable-media and cloud-upload logs
- the history of the account's access rights

5. Establishing the facts a report needs

Whatever is decided, the decision needs these facts, established as early as they can be:

- exactly what was taken, and how many people it describes
- whether it left the company - whether exfiltration is confirmed
- whether pseudonymised data in it can be linked back to people
- whether sensitive data - government ID, health data or children's accounts - is included

6. Reporting

Which reporting procedures apply is settled from the incident's facts by the rules in Plan 01, section 8, and each procedure's deadlines are read from that procedure. This playbook sets no deadline of its own, and the decision belongs to the Data Protection Officer.

Pseudonymised data taken by an insider does not qualify for the exemption in Procedure 01; if the risk is high, customers are told.

7. What affected customers should do

When customers are told, the notice gives them these steps, in this order:

- Be alert to unexpected contact from anyone who claims to know your orders or your account.
- Merrowfield will never ask for your password or payment details by email or phone.
- Tell us about anything suspicious, and quote the incident reference from our notice.

8. Closing the incident

Trim access rights to what each role needs, fix the leaver process, and enforce removable-media controls for the team.